

Default Passwords

Default passwords are often used for user accounts for testing purposes. They are easy to remember and are also used for default accounts of services and applications intended to simplify first access. It is not uncommon for such user accounts to be overlooked or forgotten. Due to the natural laziness of man, everyone tries to make it as comfortable as possible. This, in turn, leads to inattentiveness and the resulting errors, which can harm the company's infrastructure.

As we saw when we visited the website, it prompted the **Basic HTTP Authentication** form to input the username and password. Basic HTTP Authentication usually responses with an **HTTP 401 Unauthorized** response code. As we mentioned previously, we will resort to a Brute Forcing attack, as we do not have enough information to attempt a different type of attack, which we will cover in this section.

Hydra

Hydra is a handy tool for Login Brute Forcing, as it covers a wide variety of attacks and services and is relatively fast compared to the others. It can test any pair of credentials and verify whether they are successful or not but in huge numbers and a very quick manner.

If we want to use it on our own machine, we can either use "**apt install hydra -y**" or download it and use it from its [Github Repository](#) but its pre-installed on Pwnbox.

We can take a look at the options that **hydra** provides and see its flags and examples of how it can be used:

Default Passwords

```
dbcyph0n@htb[/htb]$ hydra -h
```

```
Syntax: hydra [[-l LOGIN|-L FILE] [-p PASS|-P FILE]] | [-C FILE]] [-e nsr] [-o FILE] [-t TASKS] [-M FILE] [-T
```

Options:

<...SNIP...>

```
-s PORT    if the service is on a different default port, define it here
-l LOGIN or -L FILE  login with LOGIN name, or load several logins from FILE
-p PASS    or -P FILE  try password PASS, or load several passwords from FILE
-u         loop around users, not passwords (effective! implied with -x)
-f / -F    exit when a login/pass pair is found (-M: -f per host, -F global)
server     the target: DNS, IP or 192.168.0.0/24 (this OR the -M option)
service    the service to crack (see below for supported protocols)
```

<...SNIP...>

Examples:

```
hydra -l user -P passlist.txt ftp://192.168.0.1
hydra -L userlist.txt -p defaultpw imap://192.168.0.1/PLAIN
hydra -C defaults.txt -6 pop3s://[2001:db8::1]:143/TLS/DIGEST-MD5
hydra -l admin -p password ftp://[192.168.0.0/24]/
hydra -L logins.txt -P pws.txt -M targets.txt ssh
```

Default Passwords

As we don't know which user to brute force, we will have to brute force both fields. We can either provide different wordlists for the usernames and passwords and iterate over all possible username and password combinations. However, we should keep this as a last resort.

It is very common to find pairs of usernames and passwords used together, especially when default service passwords are kept unchanged. That is why it is better to always start with a wordlist of such credential pairs -e.g. `test:test-`, and scan all of them first.

This should not take a long time, and if we could not find any working pairs, we would move to use separate wordlists for each or search for the top 100 most common passwords that can be used.

We can find a list of default password login pairs in the [SecLists](#) repository as well, specifically in the `/opt/useful/SecLists/Passwords/Default-Credentials` directory within Pwnbox. In this case, we will pick `ftp-betterdefaultpasslist.txt` as it seems to be the most relevant to our case since it contains a variety of default user/password combinations. We will be using the following flags, based on help page above:

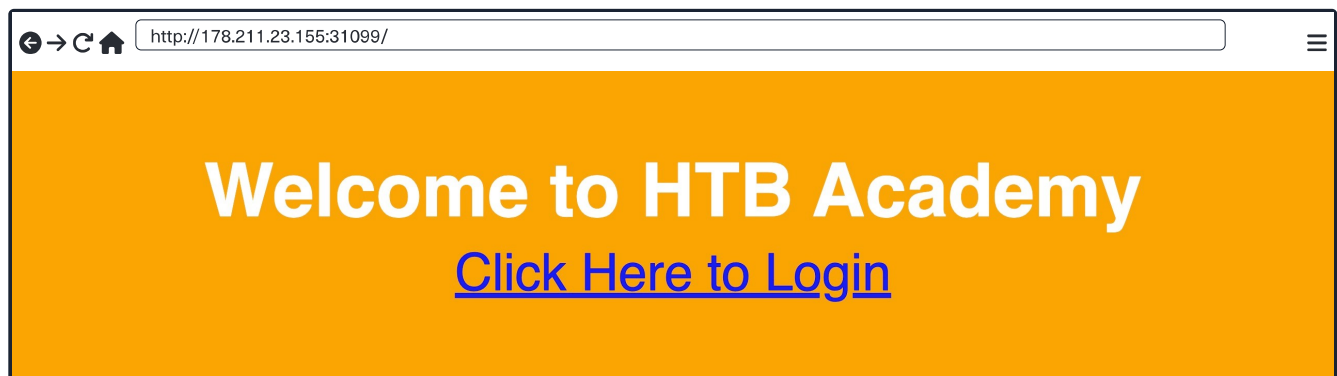
Options	Description
<code>-C ftp-betterdefaultpasslist.txt</code>	Combined Credentials Wordlist
<code>SERVER_IP</code>	Target IP
<code>-s PORT</code>	Target Port
<code>http-get</code>	Request Method
<code>/</code>	Target Path

The assembled command results:

```
Default Passwords
dbcypthon@htb[/htb]$ hydra -C /opt/useful/SecLists/Passwords/Default-Credentials/ftp-betterdefaultpasslist.txt
Hydra v9.1 (c) 2020 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organ
[DATA] max 16 tasks per 1 server, overall 16 tasks, 66 login tries, ~5 tries per task
[DATA] attacking http-get://178.211.23.155:31099/
[31099][http-get] host: 178.211.23.155 login: test password: testingpw
[STATUS] attack finished for 178.211.23.155 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
```

It's pretty common for administrators to overlook test or default accounts and their credentials. That is why it is always advised to start by scanning for default credentials, as they are very commonly left unchanged. It is even worth testing for the top 3-5 most common default credentials manually, as it can very often be found to be used.

We can visit the website again and try the same pair to verify that they do work:



As we can see, we do get access, and the pair indeed works. Next, we can try to attempt running the second type of scan by separate user wordlists for usernames and passwords and see how long it takes to find the same pair we just identified.

**Connect to Pwnbox**

Your own web-based Parrot Linux instance to play our labs.

Pwnbox Location

AU

57ms ▼

Terminate Pwnbox to switch location

Start Instance

∞ / 1 spawns left

Waiting to start...

Questions

Cheat Sheet

Answer the question(s) below to complete this Section and earn cubes!

Target: [Click here to spawn the target system!](#)

+ 0

Using the technique you learned in this section, try attacking the IP shown above. What are the credentials used?

Submit your answer here...

+10 Streak pts



Submit



Hint



Show Solution

← Previous

Next →



Cheat Sheet

? Go to Questions

Table of Contents

Table of Contents**Introduction**

Introduction to Brute Forcing

**Basic HTTP Auth Brute Forcing**

Password Attacks

 [Default Passwords](#)

Username Brute Force

Web Forms Brute Forcing

Hydra Modules

Determine Login Parameters

Login Form Attacks

Service Authentication Attacks

Personalized Wordlists

Service Authentication Brute Forcing

Skills Assessment

Skills Assessment - Website

Skills Assessment - Service Login

My Workstation

OFFLINE

Start Instance

/ 1 spawns left